

Framework Crosswalk

FinAssist Red-Team → OWASP · NIST · EU AI Act · ISO 42001 · SAIF · Bedrock

Portfolio Case Study Controls Mapping

Author: Tejaswini Dondeti • **Date:** June 2026 • **Companion file:** FrameworkCrosswalk.xlsx
Classification: Confidential — fictional institution ("Meridian First Bank")

About this document. This crosswalk shows that the FinAssist red-team isn't an isolated experiment — it maps cleanly onto the frameworks AI-governance teams actually use. The final two sections translate the work into **Google's** and **Amazon's** own language.

1. Core crosswalk

Test category	OWASP LLM Top 10 (2025)	NIST AI RMF / AI 600-1	EU AI Act	ISO/IEC 42001
1. Prompt injection & override	LLM01: Prompt Injection	Manage; GAI: Information Security	Art. 15 (robustness, cybersecurity)	A.6.2.4; A.8
2. Jailbreaks	LLM01: Prompt Injection	Manage 2.x; GAI: Dangerous Content	Art. 15; Art. 9	A.6.2.4; A.9
3. PII & data leakage	LLM02: Sensitive Info Disclosure	Map/Measure; GAI: Data Privacy	Art. 10 (data governance)	A.7; A.8.3
4. Hallucination	LLM09: Misinformation	Measure 2.x; GAI: Confabulation	Art. 13; Art. 15	A.6.2.2; A.8
5. Bias & fairness	LLM09 (+ fairness)	Measure 2.11; GAI: Harmful Bias	Art. 10 (bias examination)	A.6.2.2; A.9
6. Harmful content	LLM01 / safety	Manage; GAI: Abusive Content	Art. 9; Annex III	A.6.2.4; A.10
Cross-cutting: eval reliability	LLM05: Improper Output Handling	Measure 1.x (TEVV); Info Integrity	Art. 9; Art. 72 (post-market monitoring)	A.6.2.4; A.8.4

Mappings are indicative and to-best-knowledge; clause numbers are provided to show structural alignment, not as a certified compliance assertion.

2. Google — Secure AI Framework (SAIF)

FinAssist test area	SAIF element	How this review addresses it
Prompt injection & extraction (PI-05)	Risk: prompt injection; harden inputs, validate I/O	150-case suite; hardened prompt closed the extraction breach; defense-in-depth recommended
Jailbreaks & harmful content	Risk: model misuse; enforce policy + monitor	50 refusal cases; monitoring + continuous red-team as launch conditions
PII & data leakage	Control: protect sensitive data, output filtering	Data-leakage probes; output PII filter at launch
Bias & fairness	Responsible AI: fairness evaluation	Paired-probe fairness tests (equal treatment by name/gender)
Evaluation reliability	Detective controls; TEVV	Independent judge model; human re-grade; grader validation
Lifecycle decision	Govern deployment via launch review	Conditional-go memo with monitoring & kill-switch

3. Amazon — Bedrock Guardrails & Responsible AI

FinAssist control	AWS equivalent	Notes
Hardened refusal of disclosure / harmful asks (R2, R8)	Bedrock Guardrails: Denied topics & Content filters	The manual guardrail loop built here mirrors what Bedrock Guardrails automates
PII non-disclosure (R3, Cat 3)	Bedrock Guardrails: Sensitive Information (PII) filters / redaction	Output PII filter recommended as defense-in-depth
Prompt-injection resistance (Cat 1)	Bedrock Guardrails: Prompt attacks filter	Tested via PI-05 + 24 other injection cases
Factual-accuracy probes (Cat 4)	Bedrock Guardrails: Contextual grounding checks	Retrieve high-stakes figures from systems of record
Underlying model	Llama 3.3 70B — offered in Amazon Bedrock	Keeps the evaluation enterprise- and AWS-relevant
Launch governance	AWS Responsible AI: governance, transparency, safety pillars	System card + decision memo + risk register align to these pillars

Frameworks referenced: OWASP Top 10 for LLM Applications (2025); NIST AI RMF 1.0 and NIST AI 600-1 Generative AI Profile; EU AI Act (Regulation 2024/1689); ISO/IEC 42001:2023; Google Secure AI Framework (SAIF); AWS Bedrock Guardrails and AWS Responsible AI.